

Bonus 2: Isolamento host compromesso

Executive Summary

Il documento esamina i log raccolti durante lo sfruttamento di una vulnerabilità documentata per determinare gli host e il file compromessi attraverso l'utilizzo Kibana.

Domanda 1

Che tipo di transazioni si sono verificate tra il client e il server in questo attacco?

```
-----
DST: root:x:0:0:root:/root:/bin/bash
DST: daemon:x:1:1:daemon:/usr/sbin:/bin/sh
DST: bin:x:2:2:bin:/bin:/bin/sh
DST: sys:x:3:3:sys:/dev:/bin/sh
DST: sync:x:4:65534:sync:/bin:/bin/sync
DST: games:x:5:60:games:/usr/games:/bin/sh
DST: man:x:6:12:man:/var/cache/man:/bin/sh
DST: lp:x:7:7:lp:/var/spool/lpd:/bin/sh
DST: mail:x:8:8:mail:/var/mail:/bin/sh
DST: news:x:9:9:news:/var/spool/news:/bin/sh
DST: uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
DST: proxy:x:13:13:proxy:/bin:/bin/sh
DST: www-data:x:33:33:www-data:/var/www:/bin/sh
DST: backup:x:34:34:backup:/var/backups:/bin/sh
DST: list:x:38:38:Mailing List Manager:/var/list:/bin/sh
DST: irc:x:39:39:ircd:/var/run/ircd:/bin/sh
DST: gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
DST: nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
DST: libuuid:x:100:101:/var/lib/libuuid:/bin/sh
DST: dhcp:x:101:102:/nonexistent:/bin/false
DST: syslog:x:102:103:/home/syslog:/bin/false
DST: klog:x:103:104:/home/klog:/bin/false
DST: sshd:x:104:65534:/var/run/sshd:/usr/sbin/nologin
DST: msfadmin:x:1000:1000:msfadmin,,/home/msfadmin:/bin/bash
DST: bind:x:105:113:/var/cache/bind:/bin/false
DST: postfix:x:106:115:/var/spool/postfix:/bin/false
DST: ftp:x:107:65534:/home/ftp:/bin/false
DST: postgres:x:108:117:PostgreSQL administrator,,/var/lib/postgresql:/bin/bash
DST: mysql:x:109:118:MySQL Server,,/var/lib/mysql:/bin/false
DST: tomcat55:x:110:65534:/usr/share/tomcat5.5:/bin/false
DST: distccd:x:111:65534:/bin/false
```

Identificazione dell'utente, informazioni di rete e esfiltrazione password

Domanda 2

Cosa hai osservato? Cosa indicano i colori del testo rosso e blu?

```

id
uid=0(root) gid=0(root)
nohup >/dev/null 2>&1
echo uKgoT8McFDrCw7u2
uKgoT8McFDrCw7u2
whoami
root
hostname
metasploitable
ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:ab:84:07
          inet addr:209.165.200.235  Bcast:209.165.200.255  Mask:
255.255.255.224
          inet6 addr: fe80::a00:27ff:feab:8407/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:117 errors:0 dropped:0 overruns:0 frame:0
          TX packets:167 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:10294 (10.0 KB)  TX bytes:20187 (19.7 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:512 errors:0 dropped:0 overruns:0 frame:0
          TX packets:512 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:225633 (220.3 KB)  TX bytes:225633 (220.3 KB)

```

Il testo in **blu** rappresenta i comandi lanciati dall'attaccante mentre quelle in **rosso** rappresentano le risposte del server.

Domanda 3

Cosa rivela questo sul ruolo dell'attaccante sul computer bersaglio?

Il ruolo del bersaglio è Root quindi con poteri massimi.

Domanda 4

Scorri il flusso TCP. Che tipo di dati ha letto l'attore della minaccia?

È stata rilevata la compromissione e la lettura dei database degli utenti (**/etc/passwd**) e degli hash delle password (**/etc/shadow**).

Domanda 5

Quali sono gli indirizzi IP e i numeri di porta di origine e destinazione per il traffico FTP?

Time ▼	source_ip	source_port	destination_ip	destination_port
▶ June 11th 2020, 03:53:08.086	192.168.0.11	52776	209.165.200.235	21
▶ June 11th 2020, 03:53:09.086	192.168.0.11	52776	209.165.200.235	21

Domanda 6

Quali sono le credenziali utente per accedere al sito FTP?

- **User:** analyst
- **Password:** cyberops

SRC: USER analyst

SRC:

DST: 331 Please specify the password.

DST:

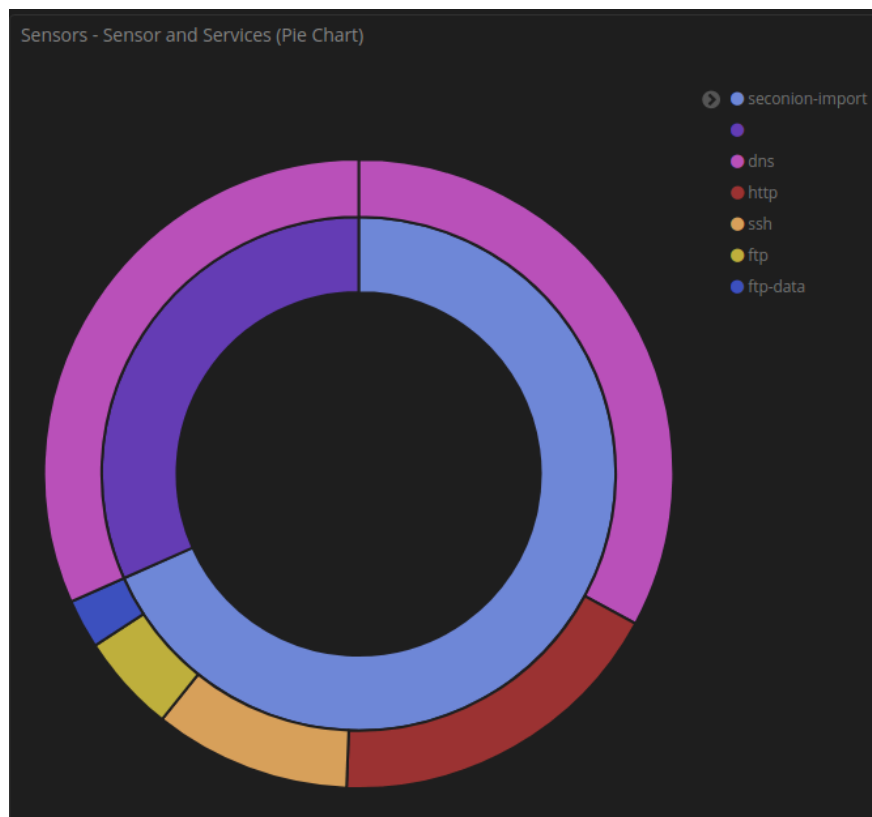
SRC: PASS cyberops

SRC:

DST: 230 Login successful.

Domanda 7

Qual è il contenuto del file? Ricorda che uno dei servizi elencati nel grafico a torta è ftp_data.

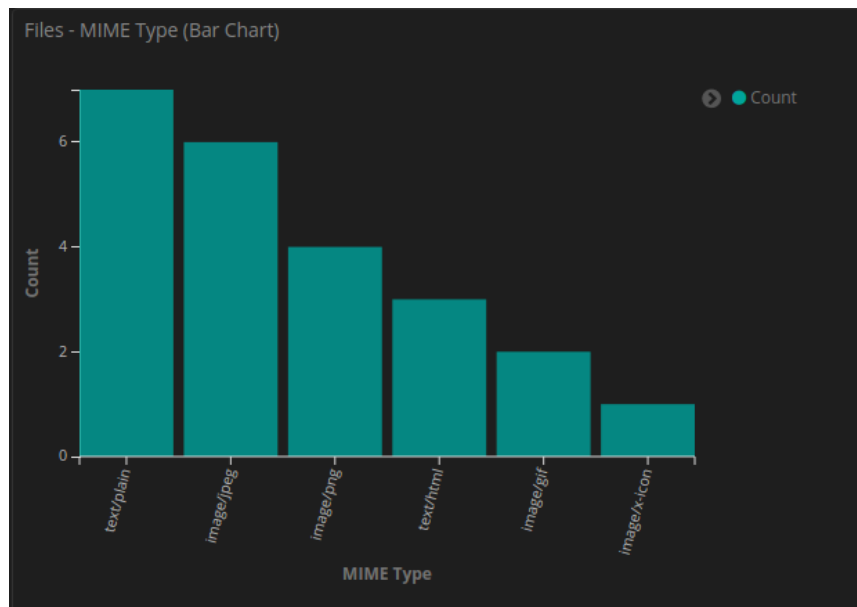


DNS

HTTP

Domanda 8

Quali sono i diversi tipi di file? Guarda la sezione MIME Type dello schermo.



Nella sezione MIME Type risultano:

- File di testo
- Immagini jpeg
- Immagini png
- testo html
- Immagini gif
- Immagini x-icon

Domanda 9

Scorri fino all'intestazione Files - Source. Quali sono le sorgenti dei file elencate?

Source	Count
HTTP	22
FTP_DATA	1

Le sorgenti elencate sono

- HTTP
- FTP_DATA

Domanda 10

Qual è il tipo MIME, l'indirizzo IP di origine e di destinazione associato al trasferimento dei dati FTP?

June 11th 2020, 03:53:09.088	192.168.0.1	209.165.200.235	Q Q	FTP_DATA	C2jv8MWV6Xg4lbb51	FX1IV63eSMAEIN16S2	KDjqzXiBB6Cd-0SVfiy
	1						

Espandendo il log si può dedurre che:

- **Fyle Type:** FTP_DATA
- **Source IP address:** 192.168.0.1
- **Destination IP address:** 209.165.200.235

Domanda 11

Quando si è verificato questo trasferimento?

Il trasferimento è avvenuto il giorno **11 giugno 2020** alle ore **03:53:09**

Domanda 12

Qual è il contenuto testuale del file trasferito tramite FTP?

SRC: CONFIDENTIAL DOCUMENT

SRC: DO NOT SHARE

SRC: This document contains information about the last security breach.

SRC:

DEBUG: Using archived data: /nsm/server_data/securityonion/archive/2020-06-11/seconion-import/192.168.0.11:49817_209.165.200.235:20-6.raw

QUERY: SELECT sid FROM sensor WHERE hostname='seconion-import' AND agent_type='pcap' LIMIT 1

CAPME: Processed transcript in 0.46 seconds: 0.12 0.20 0.00 0.14 0.00

[192.168.0.11:49817_209.165.200.235:20-6-1577393863.pcap](#)

Il contenuto testo del file FTP è il seguente:

CONFIDENTIAL DOCUMENT

DO NOT SHARE

This document contains information about the last security breach

Domanda 13

Con tutte le informazioni raccolte finora, qual è la tua raccomandazione per fermare ulteriori accessi non autorizzati?

- Isolamento dell'IP dell'attaccante, scollegarlo dalla rete.
- Reset delle password dato che l'attaccante è riuscito ad ottenerle
- Ispezione pacchetti tramite IDS